

Windows Vulnerability Assessment and Privilege Escalation

Project Description

In this project, I performed a comprehensive security assessment on a target Windows machine, identified a critical service vulnerability, and successfully escalated privileges to gain full administrative control (`NT AUTHORITY\SYSTEM`). Below is the structured breakdown of the methodology and steps taken during the penetration test:

Methodology & Execution Steps

1. Reconnaissance & Information Gathering

- Conducted initial port scanning to discover active services running on the target system, identifying an outdated version of **Iccast (Media Streaming Server)**.
- Researched the service version and mapped it to a known, critical buffer overflow vulnerability with the identifier `CVE-2004-1561` .

2. Gaining Initial Access (Foothold)

- Launched the **Metasploit Framework (MSF)** on Kali Linux and selected the relevant remote code execution (RCE) module: `exploit/windows/http/iccast_header` .
- Configured the necessary exploit parameters, including the target host (`RHOSTS`) and the attacking listener IP (`LHOST`).
- Executed the exploit to successfully compromise the machine, establishing an active **Meterpreter session** running under the context of a low-privileged local user named `Dark` .

3. Local Reconnaissance & Privilege Escalation

- Gathered system information, noting that the target was running Windows Build 7601 with an x86 process architecture.
- Utilized the `local_exploit_suggester` post-exploitation module to scan the system for missing patches and privilege escalation vectors.
- Selected and deployed the `bypassuac_eventvwr` exploit module to bypass Windows User Account Control (UAC), granting an expanded permission set that included `SeTakeOwnershipPrivilege` .

4. Process Migration & Credential Harvesting

- To interact securely with the Local Security Authority Subsystem Service (LSASS), I migrated the active Meterpreter shell into a stable, high-integrity system process: `spoolsv.exe` (Print Spooler Service).
- This successful migration upgraded my active session privileges to the highest level on the operating system: `NT AUTHORITY\SYSTEM`.
- Loaded the **Kiwi (Mimikatz)** extension into the Meterpreter session and executed the `creds_all` command to harvest cached credentials from memory, successfully retrieving the plain-text password for the user `Dark`.

5. Advanced Post-Exploitation Capabilities

- Explored various advanced post-exploitation techniques within the high-privilege shell, practicing tasks such as:
 - Dumping local SAM database password hashes (`hashdump`).
 - Monitoring the remote user's desktop in real-time (`screenshot`).
 - Modifying file timestamps to evade forensic analysis (`timestamp`).
 - Creating Active Directory persistence mechanisms using Kerberos ticket manipulation (`golden_ticket_create`).

Key Skills & Technical Competencies Demonstrated

Vulnerability Analysis: Identifying and mapping outdated software versions to specific CVE identifiers.

Metasploit Framework: Proficient handling of multi-stage payloads, listeners, and session management.

Windows Privilege Escalation: Understanding UAC bypass mechanisms, token privileges, and process migration.

Credential Dumping: Leveraging memory forensics tools (Mimikatz/Kiwi) to extract cleartext passwords and hashes.

Project Completion Evidence

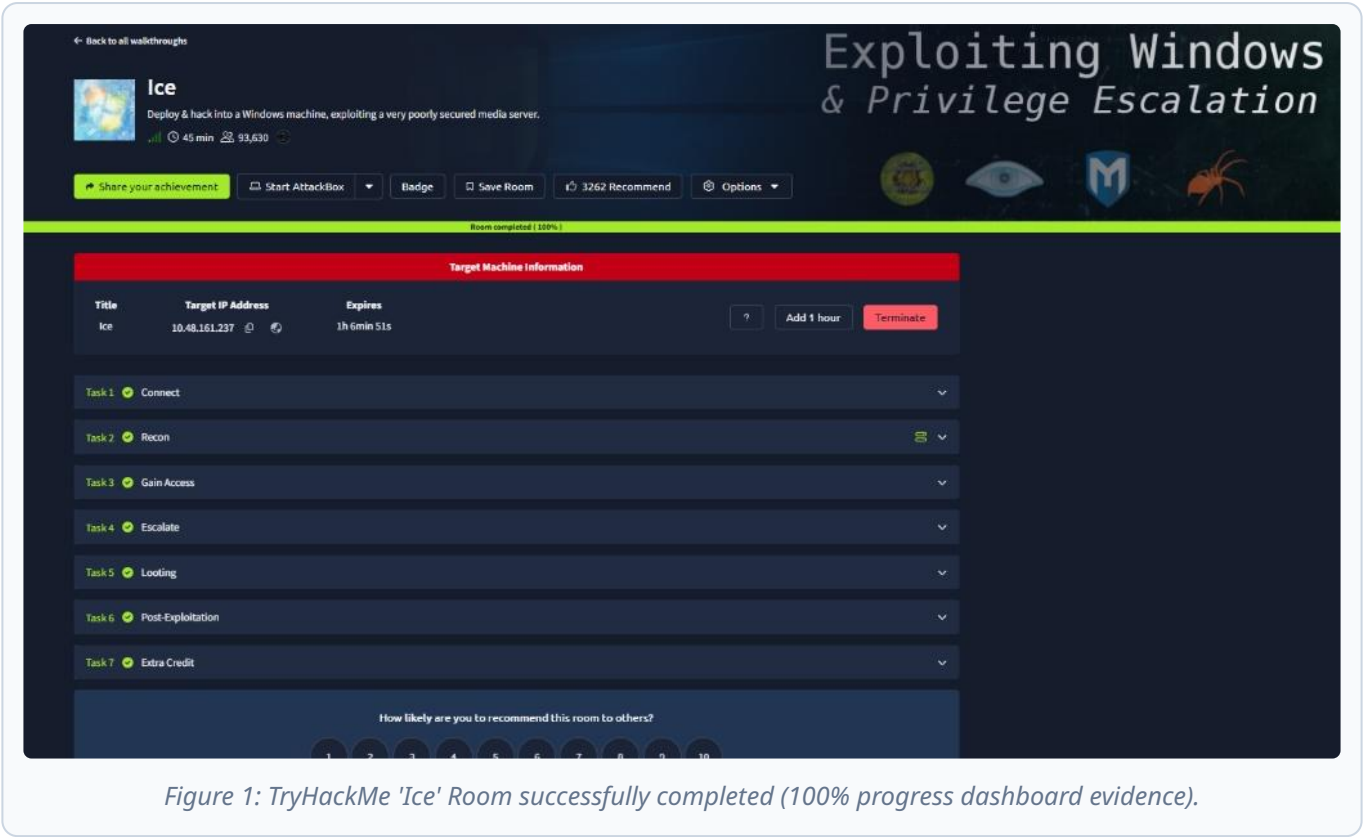


Figure 1: TryHackMe 'Ice' Room successfully completed (100% progress dashboard evidence).